Privacy-Policy

Privacy Policy — nexus

ⓘ What this document is

The binding disclosure of what personal data nexus collects, why, how long it is kept, who it is shared with, and what rights the data subject can exercise. Operative text plus the reasoning behind each clause. The reasoning is not part of the agreement — it exists so that a future editor understands why a clause was written the way it was, and what would break if it changed.

⚠ Not legal advice

This is a working draft. Have counsel review it against the data protection laws of every jurisdiction where the Service operates or is offered. The document is written to be jurisdiction-agnostic where possible and to flag where a jurisdiction-specific choice is required. Do not publish without filling every placeholder and completing the data inventory table.

Overview

PRIVACY_POLICY.md is the third of six documents in the nexus legal suite. It sits between the LICENSE (which governs the software) and the TERMS_OF_USE.md (which governs the service relationship). It answers the question neither of those documents answers: *what happens to the personal data that flows through nexus?*

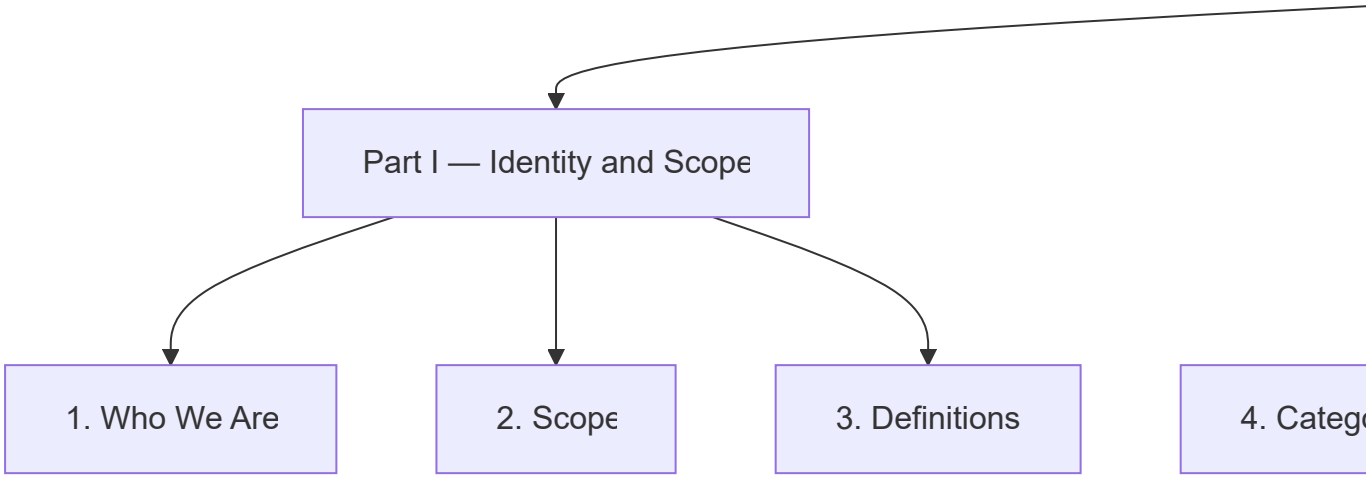
Three audiences read this document.

Audience	What they need from it
End users of a hosted nexus instance	Know what is collected about them, and what they can do about it
Operators who deploy nexus for others	Know what they are legally required to disclose, and what they must do to comply
Data protection authorities and DPOs	Verify that the processing has a lawful basis and that data subject rights are actually exercisable

The nexus privacy posture in one sentence

nexus is built to collect as little personal data as possible, to hash what it must collect, to encrypt what it stores, and to delete what it no longer needs. Most of this document is the discipline of *not* collecting things, not the disclosure of collecting them.

Document structure at a glance



The four-part division mirrors the TERMS_OF_USE.md structure. Part I establishes scope and identity. Part II is the disclosure of what is collected. Part III is the operational discipline. Part IV is the exercise of rights.

Part I — Identity and Scope

1. Who We Are

Operative text

The data controller for personal data processed through the Service is **[OPERATOR LEGAL NAME]**, a **[COMPANY TYPE]** registered in **[JURISDICTION]** at **[REGISTERED ADDRESS]**, with company registration number **[NUMBER]**. For questions about this Policy or to exercise your data protection rights, contact our Data Protection Officer at **[DPO EMAIL]**.

Every bracketed field must be filled before publishing

A privacy policy that does not name a real legal entity is unenforceable under GDPR Art. 13(1)(a), CCPA §1798.130(a)(5)(A), and equivalent statutes in every major jurisdiction. The DPO email must be a monitored mailbox. If you do not have a DPO, the contact can be a generic privacy mailbox, but it must be someone with authority to answer requests.

Drafting note. The controller is the entity that determines the purposes and means of processing. In a self-hosted nexus deployment, the operator of the instance is the controller. In a SaaS deployment, the operator of the SaaS is the controller for account data, and the customer is the controller for any data they submit. See Data Processing Agreement for the B2B case.

2. Scope of This Policy

Operative text

This Policy applies to all personal data processed by the Service. It does not apply to any third-party website, service, or application that the Service fetches on your behalf, or that you reach through a link from the Service. Those third parties have their own privacy policies, which you should read separately.

Why this clause exists

nexus fetches content from arbitrary targets. If a user scrapes `example.com`, the privacy policy of `example.com` applies to that interaction, not the privacy policy of nexus. This clause draws the line: nexus is responsible for what nexus collects, and only that.

Drafting note. If the Service sends users to third-party sites (for example, search results that they then click through to), consider adding a specific clause about cookies set by those sites and the fact that nexus does not control them.

3. Definitions

Operative text

"Personal Data" has the meaning given in Article 4(1) of the GDPR (or the equivalent definition under the data protection law of your jurisdiction): any information relating to an identified or identifiable natural person.

"Processing" means any operation performed on Personal Data, including collection, storage, use, disclosure, and deletion.

"Data Subject" means the individual to whom Personal Data relates.

"Controller" means the entity that determines the purposes and means of Processing. For this Service, that is the Operator named in Section 1.

"Processor" means an entity that processes Personal Data on behalf of the Controller. See Section 8 for the list of processors used by this Service.

"Sensitive Personal Data" means any category of Personal Data given enhanced protection under applicable law, including health data, biometric data, racial or ethnic origin, political opinions, religious beliefs, trade union membership, genetic data, and data concerning sex life or sexual orientation.

Why this clause exists

Every subsequent clause uses these terms. Defining them once prevents cross-clause ambiguity. The definitions match the ones in TERMS_OF_USE.md so that a reader of both documents sees the same vocabulary.

Drafting note. The definitions are drawn from GDPR because it is the most prescriptive framework. Where a jurisdiction uses different terminology (for example, CCPA uses "consumer" instead of "data subject"), the clause can be amended to add the local term without losing the GDPR baseline.

Part II — What We Collect and Why

4. Categories of Personal Data

Operative text

The Service collects the following categories of Personal Data. This table is the complete inventory. If a category is not listed, the Service does not collect it.

Category	Examples	Source	Where it is stored
Request metadata	Timestamp, HTTP method, request path, response status, latency in milliseconds	Server middleware	SQLite `request_log` table

Category	Examples	Source	Where it is stored
Hashed IP address	HMAC-SHA256 of your IP with a server-side key	Server middleware	SQLite `request_log.ip_hash` column
Exact IP address *(only if enabled by the Operator)*	Your full IPv4 or IPv6 address	Server middleware	SQLite `request_log.ip_exact` column
Request identifier	A random UUID generated for each request	Server middleware	SQLite `request_log.request_id` column
Service input	The URL or query you submit	You	Not persisted; held in memory for the duration of the request
Cached content *(only if the Operator enables caching)*	Extracted text from the target you requested, encrypted at rest	Pipeline output	SQLite `cache_entry` table (encrypted)
Session identifier *(only if the Operator enables accounts)*	A JWT signed by the server	Auth layer	Client-side only; not stored server-side
Client-side cache	Compressed JSON of your recent requests	Your browser	Your browser's `localStorage`

> **⚠ The most important clause in this document**
>
> The default deployment of nexus does **not** store exact IP addresses. The default stores an HMAC hash of the IP, which is sufficient for abuse correlation but not reversible. Exact IP storage is opt-in via the environment variable `NEXUS_STORE_EXACT_IP=1`, and enabling it constitutes a material change in the risk posture of the deployment. If the Operator has enabled it, that fact must be disclosed prominently here.

Drafting note. If the Operator has enabled exact IP storage, replace the "*(only if enabled by the Operator)*" row with an explicit disclosure. Do not bury it. Several data protection authorities have issued fines for exact-IP retention without a documented lawful basis.

Drafting note. If the Operator has enabled any feature that stores additional data (for example, a `jobs` table for scheduled scrapes, or a `users` table for accounts), add rows to this table. The table must be exhaustive — a privacy policy that omits a category of collected data is a compliance violation in itself.

5. Purposes of Processing

Operative text

The Service processes Personal Data only for the following purposes.

5.1 Abuse prevention. Request metadata, hashed IP addresses, and request identifiers are processed to detect and prevent abuse, rate-limit violations, denial-of-service attempts, and unauthorized access.

5.2 Service operation. Cached content and session identifiers are processed to operate the Service, respond to your requests, and maintain continuity across requests.

5.3 Security and integrity. All categories of Personal Data may be processed to detect, investigate, and respond to security incidents, and to maintain the integrity of the Service.

5.4 Legal compliance. Personal Data may be processed to comply with legal obligations, respond to lawful requests from public authorities, and exercise or defend legal claims.

5.5 Service improvement. Aggregated, anonymized request metrics may be processed to understand usage patterns and improve the Service. Aggregate metrics do not contain Personal Data.

Why this clause exists

GDPR Art. 5(1)(b) requires that Personal Data be collected for specified, explicit, and legitimate purposes, and not further processed in a manner incompatible with those purposes. This clause is the "specified purposes" statement. It is exhaustive — if a purpose is not listed, the Operator may not process data for it without updating this Policy.

Drafting note. "Service improvement" is deliberately limited to aggregated, anonymized metrics. Processing Personal Data for improvement without anonymization requires additional disclosure and, in most jurisdictions, a stronger lawful basis.

6. Legal Basis

Operative text

Where the GDPR applies, the Service relies on the following legal bases for processing.

Purpose	Legal Basis	GDPR Article
Abuse prevention	Legitimate interests	Art. 6(1)(f)
Service operation	Performance of a contract	Art. 6(1)(b)
Security and integrity	Legitimate interests	Art. 6(1)(f)
Legal compliance	Legal obligation	Art. 6(1)(c)
Service improvement	Consent or legitimate interests (aggregated only)	Art. 6(1)(a) or (f)

Why this clause exists

GDPR Art. 6 requires a legal basis for every processing activity. This table maps each purpose to its basis. Where the basis is legitimate interest, the Operator must have completed a Legitimate Interest Assessment (LIA) documenting that the interest outweighs the data subject's rights. See Legitimate Interest Assessment.

Drafting note. If the Operator uses cookies or similar technologies, additional consent may be required under the ePrivacy Directive. See Section 7.

7. Cookies and Local Storage

Operative text

The Service does not set cookies by default. Session authentication, if enabled, uses a JWT passed in the HTTP `Authorization` header, not a cookie.

The Service uses browser `localStorage` to cache recent results on your device. This cache is entirely client-side. It is not transmitted to the server. It can be cleared at any time through your browser settings. If you clear it, the Service will re-fetch any URLs you request.

The Service loads assets from third-party CDNs (Google Fonts, cdnjs, DuckDuckGo's favicon service). Those CDNs may set cookies or receive your IP address when your browser loads their assets. Those cookies are not controlled by the Operator. See Section 8 for the full list of third parties.

The third-party CDN problem

The client loads fonts from `fonts.googleapis.com`, an icon library from `cdnjs.cloudflare.com`, and favicons from `icons.duckduckgo.com`. Each of these calls sends your IP address and browser headers to the respective CDN. If you are in

the EU, this is a data transfer to a third country (Google and Cloudflare are US-based, DuckDuckGo is US-based). Some data protection authorities consider this a violation without prior consent.

To fully mitigate: bundle the fonts and icons locally and remove the third-party CDN calls. This is a one-day change to `index.html` and worth doing before EU launch.

Drafting note. If the Service is deployed in the EU or offers service to EU users, a standalone Cookie Policy may be required, plus a cookie consent banner. The current Policy mentions third-party CDNs but does not implement consent. This is a compliance gap.

Part III — How We Handle It

8. Sharing and Disclosure

Operative text

The Service does not sell Personal Data. The Service does not share Personal Data with third parties for marketing purposes. Personal Data may be shared only in the following circumstances.

8.1 Processors. The Service uses third-party service providers to operate. Each provider processes Personal Data only on documented instructions from the Operator. The current list of processors is:

Processor	Role	Location	Data shared
DuckDuckGo	Favicon resolution	United States	Domain name of target URL (from your browser)
Google Fonts	Font delivery	United States	Your IP address, browser headers (from your browser)
Cloudflare CDN	Icon delivery	Global (US primary)	Your IP address, browser headers (from your browser)
GitHub	Repository API (if you use `github:` inputs)	United States	Your query string
Hugging Face	Model API (if you use `hf:` inputs)	France / United States	Your query string
The target site	The URL you requested	Wherever the target is hosted	Your request for the target URL

⚠ These are data flows the user triggers, not flows the Operator controls

Every row in that table is a data flow that happens because the user requested something. If you paste `https://example.com` into the client, your browser fetches `example.com`'s favicon from DuckDuckGo. DuckDuckGo learns that a client at your IP is interested in `example.com`. This is a real disclosure. It is documented here so that the user can decide whether to accept it.

> **8.2 Legal requirements.** Personal Data may be disclosed to public authorities in response to a lawful request, or to comply with a legal obligation. Where permitted by law, the Operator will notify the affected user of such a request.
>
> **8.3 Business transfers.** If the Operator is acquired, merged, or sells substantially all of its assets, Personal Data may be transferred as part of that transaction. The acquiring entity will be bound by this Policy unless the user is notified otherwise and given the opportunity to opt out.
>
> **8.4 Consent.** Personal Data may be shared with a third party if you have given explicit consent to that sharing.

Drafting note. GDPR Art. 28 requires a Data Processing Agreement (DPA) with each processor. DuckDuckGo, Google, Cloudflare, GitHub, and Hugging Face each offer standard DPAs that can be signed and referenced. See Data Processing Agreement and Sub-processors.

9. International Transfers

Operative text

Personal Data may be transferred to, and processed in, countries outside the country in which you reside. These countries may have data protection laws that differ from the laws of your country. When Personal Data is transferred internationally, the Operator ensures that appropriate safeguards are in place, including Standard Contractual Clauses approved by the European Commission, adequacy decisions, or equivalent mechanisms under applicable law.

The primary international data flows created by using the Service are:

- Your browser → DuckDuckGo (favicon), Google (fonts), Cloudflare (icons) — all US-based.
- The Service server → GitHub (US) and Hugging Face (France) — when you use those prefixes.
- The Service server → the target site you requested — in the target's jurisdiction.

⚠ Schrems II implications

The Court of Justice of the European Union's 2020 judgment in *Schrems II* invalidated the EU-US Privacy Shield and required a Transfer Impact Assessment (TIA) for any EU-to-US transfer relying on Standard Contractual Clauses. If the Operator's primary users are in the EU and the Operator's processors are US-based, a TIA is required for each processor. This is a legal gap in the current draft that must be closed before EU launch.

Drafting note. If the Operator operates entirely within a single jurisdiction with no cross-border data flow, this section can be simplified to a single sentence: "We do not transfer Personal Data outside [JURISDICTION]." But given that the client loads Google fonts and DuckDuckGo favicons, this is unlikely to be true for any real deployment.

10. Retention

Operative text

Personal Data is retained only as long as necessary for the purposes described in Section 5.

Category	Retention Period	Rationale
Request metadata (`request_log`)	30 days	Sufficient to detect and investigate abuse patterns
Hashed IP (`request_log.ip_hash`)	30 days	Matches request log retention; abuse correlation window
Exact IP (`request_log.ip_exact`) *if enabled*	30 days	Same window; kept only when legally justified
Request identifier (`request_log.request_id`)	30 days	Enables correlation with application logs
Cached content (`cache_entry`)	15 minutes to 24 hours, per-type TTL	Configurable; shorter for volatile content
Session identifier (JWT)	Session lifetime	Expired tokens become invalid automatically
Client-side cache (`localStorage`)	Until evicted by LRU or cleared by you	Lives entirely on your device

> After the retention period, Personal Data is deleted or anonymized. Deleting the `request_log` rows is done automatically on a schedule defined by the Operator. You can also request deletion at any time by contacting the DPO.

Why 30 days

Thirty days is a common baseline for operational logs. It is long enough to investigate a security incident that is discovered late, and short enough to satisfy most data minimization requirements. Some jurisdictions (for example, Germany) require shorter retention for operational logs without a specific legal basis. The number should be set based on the Operator's actual incident response timeline and the local legal baseline.

Drafting note. The `delete_old` function in the server's storage layer already implements the retention purge. The retention window is a single config value. If the Operator changes it, this table must be updated in the same release.

11. Security

Operative text

The Operator implements technical and organizational measures designed to protect Personal Data against unauthorized access, alteration, disclosure, or destruction. These measures include:

- **Encryption in transit.** All communication between your browser and the Service uses HTTPS (TLS 1.2 or higher).
- **Encryption at rest.** Sensitive stored data, including cached content, is encrypted with AES-256-GCM.
- **Password hashing.** If the Service supports user accounts, passwords are hashed with Argon2id using industry-standard parameters.
- **Access controls.** Server access is restricted to authorized personnel using strong authentication.
- **Rate limiting.** Requests are rate-limited per IP and per route to prevent abuse.
- **SSRF protection.** The Service blocks requests to loopback, private, link-local, and cloud metadata endpoints.
- **Structured logging with redaction.** Logs are structured and sensitive fields are automatically redacted before writing.

No system is perfectly secure. The Operator cannot guarantee that unauthorized access will never occur.

⚠ What is *not* in this list

The current implementation does not include: hardware security modules, database-level access controls beyond file permissions, network segmentation, intrusion detection systems, or continuous vulnerability scanning. These are enterprise-grade measures that a small deployment does not typically implement. If the Service handles sensitive categories of data, the Operator should add these or clearly state their absence.

Drafting note. GDPR Art. 32 requires "appropriate technical and organizational measures." The word "appropriate" is interpreted relative to the risk. For a small deployment handling a handful of users' request logs, the current measures are proportionate. For a deployment handling financial or health data, they are not.

12. Breach Notification

Operative text

If the Operator becomes aware of a Personal Data breach that poses a risk to the rights and freedoms of data subjects, the Operator will:

12.1 Notify the competent supervisory authority without undue delay and, where feasible, within 72 hours of becoming aware of the breach, as required by GDPR Art. 33 (or the equivalent requirement under applicable law).

12.2 Notify affected data subjects without undue delay if the breach is likely to result in a high risk to their rights and freedoms, as required by GDPR Art. 34.

12.3 Document the breach, its effects, and the remedial action taken, as required by GDPR Art. 33(5).

Notification will include, where known: the nature of the breach, the categories and approximate number of data subjects affected, the likely consequences, and the measures taken or proposed to address the breach.

Why this clause exists

The 72-hour window is a GDPR hard requirement. It is calculated from the moment the Operator becomes aware of the breach, not from the moment the breach occurred. Documentation is required even if notification is not triggered.

Drafting note. The breach notification clause is operative only if the Operator has a documented incident response procedure. Without one, the 72-hour window will be missed. See Incident Response Plan.

Part IV — Your Rights and Administration

13. Your Rights

Operative text

Depending on your jurisdiction, you may have the following rights with respect to your Personal Data.

13.1 Right of access. You may request a copy of the Personal Data the Service holds about you.

13.2 Right to rectification. You may request correction of inaccurate Personal Data.

13.3 Right to erasure. You may request deletion of your Personal Data. This right is not absolute — some data must be retained for legal compliance or security purposes.

13.4 Right to restrict processing. You may request that the Service stop processing your Personal Data for specific purposes.

13.5 Right to data portability. You may request your Personal Data in a structured, commonly used, machine-readable format.

13.6 Right to object. You may object to processing based on legitimate interests. The Operator will stop unless there are compelling legitimate grounds.

13.7 Right to withdraw consent. Where processing is based on consent, you may withdraw it at any time. Withdrawal does not affect the lawfulness of processing before withdrawal.

13.8 Right to lodge a complaint. You have the right to lodge a complaint with a supervisory authority in your jurisdiction.

To exercise any of these rights, contact the DPO at **[DPO EMAIL]**. Requests will be answered within 30 days (or the shorter period required by your jurisdiction).

⚠ The rights are not uniform across jurisdictions

GDPR grants all eight rights above. CCPA/CPRA grants a subset with different names (right to know, right to delete, right to correct, right to opt out of sale/sharing, right to limit use of sensitive data). Other jurisdictions have their own variations. If the Service is offered globally, this section should be jurisdiction-specific — either by adding a "Jurisdiction-Specific Rights" subsection or by producing a multi-jurisdiction variant via the `multi-juris` module.

Drafting note. GDPR Art. 12(3) requires a response within one month. CCPA requires 45 days. The Service should respond within the shorter of the applicable periods. The "within 30 days" phrase is the safest common denominator.

14. Children's Privacy

Operative text

The Service is not directed to children under the age of 16 (or the age of digital consent in your jurisdiction, whichever is higher). The Service does not knowingly collect Personal Data from children. If the Operator becomes aware that a child has provided Personal Data, the Operator will delete it promptly. If you believe a child has provided Personal Data, contact the DPO at **[DPO EMAIL]**.

Why this clause exists

COPPA (US) sets the threshold at 13. GDPR sets it at 16 by default, with member states free to lower it to 13. The clause uses 16 as the conservative baseline. If the Service operates exclusively in the US, the threshold can be 13. If it operates globally, 16 is the safe default.

Drafting note. If the Service has any features that might appeal to children (for example, an educational deployment), additional obligations may apply under COPPA, GDPR Art. 8, and equivalent statutes.

15. Changes to This Policy

Operative text

The Operator may update this Policy at any time. The current version will always be available at the URL where this Policy is published, with an "Last Updated" date at the top. Material changes will be communicated through the Service itself and, if you have provided an email address, by email. Continued use of the Service after a material change constitutes acceptance of the updated Policy.

Why this clause exists

Privacy policies evolve as the Service evolves. This clause allows the Operator to update the Policy without obtaining fresh consent from every user. However, some jurisdictions require affirmative consent for material changes — see the drafting note below.

Drafting note. GDPR does not require affirmative consent for privacy policy updates as long as the changes are transparent and the user has the ability to withdraw. CCPA requires notice. Some jurisdictions require opt-in for material changes. If the Operator's users are primarily in the EU, the "notification + continued use" pattern is acceptable. If the user base is mixed, consider requiring affirmative consent for material changes.

16. Contact

Operative text

For questions, requests, or complaints about this Policy:

Data Controller: [OPERATOR LEGAL NAME]
Postal Address: [REGISTERED ADDRESS]
Privacy Contact: [DPO EMAIL]
EU Representative (if applicable): [EU REPRESENTATIVE NAME AND ADDRESS]
UK Representative (if applicable): [UK REPRESENTATIVE NAME AND ADDRESS]

If you are not satisfied with the response to a privacy request, you have the right to lodge a complaint with the supervisory authority of your jurisdiction. A list of EU supervisory authorities is available from the European Data Protection Board.

⚠ The EU and UK representative requirement

GDPR Art. 27 requires controllers not established in the EU to appoint a representative in the EU if they offer services to EU data subjects. The UK GDPR has the same requirement for the UK. If the Operator is based outside the EU or UK and offers service to users there, representatives must be appointed and their details disclosed here.

Data inventory — the operational table

The single most useful page in this document

A data protection authority reviewing the Policy will look first at whether the disclosure matches the actual processing. The table below is the operational reference — what the code actually does, independent of the disclosure text.

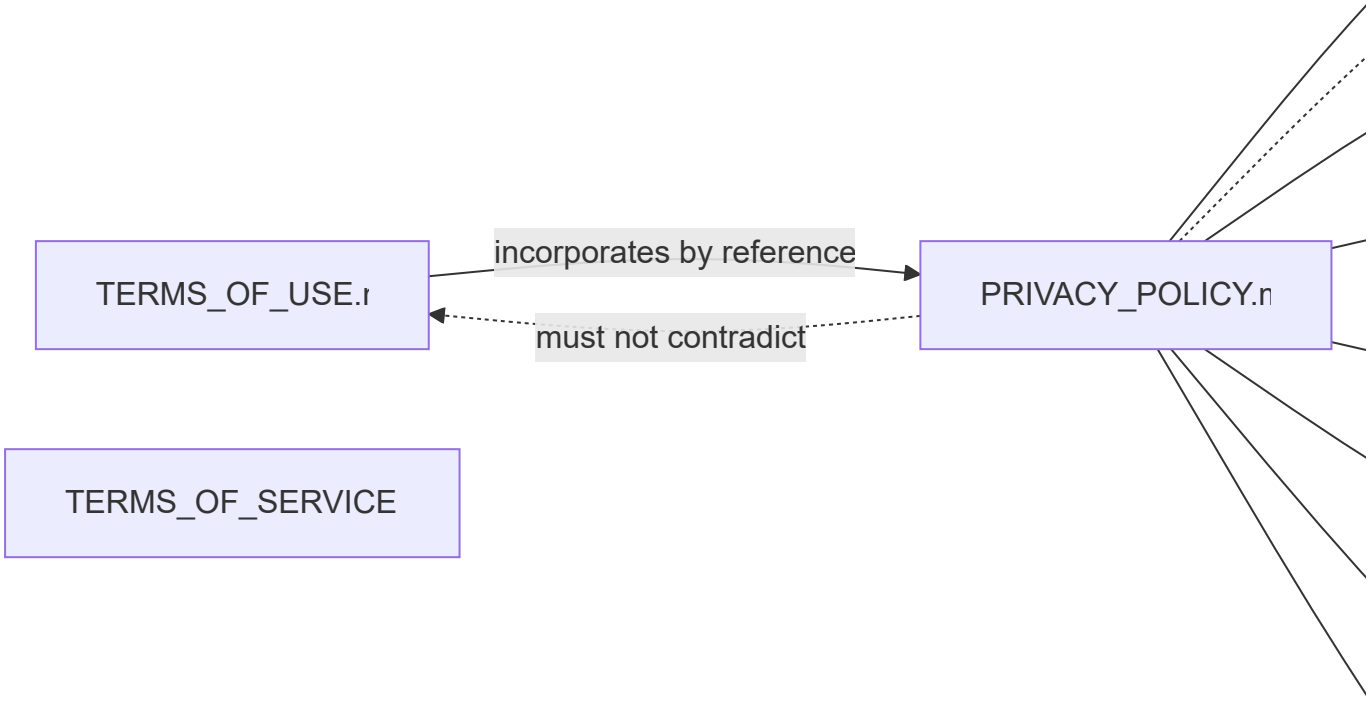
Data	Collection point	Storage	Encrypted?	Retention	Lawful basis
Request method	HTTP middleware	SQLite `request_log.method`	No	30 days	Legitim interest
Request path	HTTP middleware	SQLite `request_log.path`	No	30 days	Legitim interest
Response status	HTTP middleware	SQLite `request_log.status`	No	30 days	Legitim interest
Latency	HTTP middleware	SQLite `request_log.latency_ms`	No	30 days	Legitim interest
IP hash (HMAC)	HTTP middleware	SQLite `request_log.ip_hash`	No (already hashed)	30 days	Legitim interest
IP exact	HTTP middleware (opt-in)	SQLite `request_log.ip_exact`	No	30 days	Legitim interest
Request ID	HTTP middleware	SQLite `request_log.request_id`	No	30 days	Legitim interest
Scraped text	Pipeline	SQLite `cache_entry.ciphertext`	Yes (AES-GCM)	Per-type TTL	Contra
JWT	Auth layer	Client-side only	N/A	Session	Contra
Browser cache	Client JS	`localStorage`	No	Until evicted	Conser (implici

What is *not* collected

The Service does not collect: email addresses (unless accounts are enabled), usernames, profile information, payment data, geolocation, device fingerprints, or cross-site tracking identifiers. The table above is the complete inventory of what is actually stored.

Drafting note. If the Operator adds any new feature that collects data — a `jobs` table, an `api_keys` table, an `audit_log` table with actor identity — the table above must be updated in the same release as the feature. A privacy policy that does not match the code is worse than no privacy policy.

Cross-document connections



Contradiction scan before publishing

Read the following pairs side by side.

- **PRIVACY_POLICY vs TERMS_OF_USE** — the ToU says "we may suspend your account." The Privacy Policy says "we retain data for 30 days." These must not conflict about what happens to data after account termination.
- **PRIVACY_POLICY vs LICENSE** — the LICENSE says "you may fork and self-host." The Privacy Policy describes the Operator's deployment. These describe different entities and should not be conflated.
- **PRIVACY_POLICY vs DATA PROCESSING AGREEMENT** — the DPA must name the same sub-processors as Section 8 of this Policy. A mismatch is a compliance failure.
- **PRIVACY_POLICY vs RETENTION_SCHEDULE** — the numbers must match exactly. A mismatch will be flagged by any competent auditor.

Sub-topics worth their own notes

- Data Inventory — the operational table that must always match the code
- Lawful Basis — GDPR Art. 6 analysis for each processing activity
- Legitimate Interest Assessment — required documentation for LIA-based processing
- Retention Schedule — the schedule that must match Section 10
- Data Subject Rights — how each of the eight rights is actually exercised
- International Transfers — Transfer Impact Assessments for each processor
- Sub-processors — the list in Section 8 expanded with contracts and contact details
- Data Processing Agreement — for B2B customers who are controllers
- Cookie Policy — if EU deployment requires a standalone cookie policy
- Incident Response Plan — the procedure that supports Section 12
- Breach Notification Playbook — the 72-hour checklist
- EU Representative — appointment if the Operator is outside the EU
- UK Representative — appointment if the Operator is outside the UK
- Children's Privacy — the analysis behind the 16-year threshold
- Anonymization vs Pseudonymization — the technical distinction behind the HMAC-IP design

---

Examples in the wild

Three real privacy policies worth studying.

Service	Why worth studying
Mozilla Firefox Privacy Notice	Model for a technical audience. Uses tables and structured data to disclose collection without legalese.
Basecamp Privacy Policy	Model for a small operator. Plain language, limited scope, no hedging.
Cloudflare Privacy Policy	Model for a service with many sub-processors. The sub-processor table is a template for Section 8.

What to borrow

From Mozilla: the structured data disclosure table (already applied in Section 4). From Basecamp: plain language that respects the reader. From Cloudflare: the explicit sub-processor list with locations.

Open questions

Unresolved

- **What is the Operator's identity?** Sections 1 and 16 must be filled with real values before publication.
- **Is exact IP storage enabled?** The default is off. If it is on, Section 4 must be more explicit. Determine and disclose.
- **Is there an account system?** If yes, the retention row for JWT becomes operative, and a `TERMS_OF_SERVICE.md` is required in parallel. If no, that row can be dropped.
- **What is the primary jurisdiction?** The GDPR-specific sections assume EU users. If the Operator serves only US users, CCPA/CPRA provisions must replace them.
- **Has a Legitimate Interest Assessment been completed?** Section 6 relies on legitimate interest for abuse prevention. Without an LIA, that basis is unsupported. The LIA is a required document, not optional.
- **Is the Service offered to businesses?** If yes, a Data Processing Agreement is required and the B2B privacy obligations are different from the B2C ones.
- **Are the third-party CDN calls acceptable?** Google Fonts and DuckDuckGo favicon calls leak user IPs to third parties. If the Operator wants to eliminate this exposure, the fonts and icons must be bundled locally.
- **Is there an EU or UK representative?** If the Operator is outside those regions and offers service there, one must be appointed.
- **Is the retention period 30 days, or is it set by a legal requirement?** Some jurisdictions require shorter periods for operational logs. The number should be

justified by local law, not chosen arbitrarily.

- **What is the breach response capability?** Section 12 promises a 72-hour notification. Without a documented incident response procedure, that promise will not be kept.
- **Is there a children's privacy risk?** If the Service could plausibly attract users under 16, the children's privacy section may need to be strengthened or an age gate added.
- **Is a cookie consent banner required?** If the Service is deployed in the EU, the ePrivacy Directive likely requires prior consent for the third-party CDN calls. This is a compliance gap.

Document version: 1.0.0 · **Effective:** upon publication · **Next review:** after jurisdiction and data inventory are finalized.